SOFTWARE ENGINEERING / LAB 5

Static Code Analysis

Student Grade System

Samarth Kotian | PES1UG24CS406

30 October 2026

1. Introduction and results

Static code analysis examines source code without executing it to identify likely bugs, unsafe patterns, maintainability issues, and style violations. This lab applies three complementary tools to the assigned student grade and transcript manager.

Tool	Purpose	Before	After
Pylint 4.1.3	Code quality, likely errors, naming and maintainability	5.51/10; 22 messages	10.00/10; no messages
Bandit 1.9.4	Python security patterns and vulnerable API usage	6 findings: 2 High, 1 Medium, 3 Low	0 findings
Flake8 7.5.0	PEP 8 style, unused names and syntax checks	8 findings	0 findings; silent success

Verification: Python 3.12.14; all final analyzer exit codes are 0; all 10 regression tests pass. The sample GPA is still 4.35 after recording S01's score of 95.

Evidence included: a prioritized issue table, six before-and-after screenshots, complete contents of all six analyzer text reports, and four standard reflection answers.

Assigned source: https://github.com/SETAPESU26/L5_42_student_grade_system

Individual submission: https://github.com/samarthkotian/software_engineering_lab/tree/main/lab5

Analysis uses default enabled checks. No warning suppressions, ignored rules, or `# nosec` comments were introduced.

2. Issue identification: security

Original line numbers refer to the unchanged supplied source in `reports/before/student_grade_system.py`. High and Medium security findings appear first. Severity labels come from Bandit.

Issue	Type	Lines	Description	Fix approach
B324: weak MD5 hash	Security - High	49	MD5 is unsuitable for security-sensitive hashing.	Use `hashlib.sha256` with UTF-8 input. This is an identifier digest, not password storage.
B605: shell execution	Security - High	60	A filename is concatenated into an `os.system` command, allowing shell metacharacters to be interpreted.	Remove the shell invocation and print the completion message directly.
B307 / W0123: `eval`	Security - Medium	44	Evaluating a supplied GPA expression can execute arbitrary Python code.	Replace expression evaluation with validated numeric scaling: mean score divided by a positive finite scale. Update the demo call.
B110 / W0702 / E722: bare exception and silent `pass`	Security - Low / reliability	26-27	All exceptions, including programming errors, are silently swallowed.	Validate student membership and attendance bounds explicitly; return a success flag. Unexpected programming errors remain visible.
B311: predictable PIN generation	Security - Low	53	`random.randint` is not suitable for generating security-sensitive PINs.	Use `secrets.randbelow(9000) + 1000` to preserve the four-digit range.
B105: hardcoded portal token	Security - Low	64, 72	An embedded credential is also printed to the console.	Read optional `GRADE_PORTAL_TOKEN` from the environment and print only its Boolean presence.

All six Bandit findings were resolved. The shell call was removed entirely; GPA expressions were replaced by direct arithmetic. No unsafe call was retained behind a suppression.

2. Issue identification: quality and style

The following tool findings overlap in places. They are grouped by cause so the table describes the actual repair rather than counting each warning as an unrelated bug.

Issue	Type	Lines	Description	Fix approach
W0102: mutable default list	Bug / quality	15	The same default audit list is shared across function calls.	Default to `None` and allocate a fresh list inside `add_grade`. Caller-provided lists remain supported.
W1514 / R1732: unsafe resource handling	Reliability / quality	57-59	The file has no explicit encoding and may stay open if writing raises an error.	Use a context manager with explicit UTF-8 encoding. File errors propagate to the caller.
C0103 / C0116: naming and missing docstrings	Maintainability	15, 23, 30, 41, 48, 52, 56, 63	The function name `addGrade` violates snake_case and functions lack documentation.	Rename it to `add_grade`, update the caller, and document each function.
W0611 / F401 / W0612 / F841: unused code	Quality / style	6, 31, 43	`json` and `grace_marks` are unused. `avg_score` is only referenced dynamically inside `eval`, so analyzers cannot see its use.	Remove the unused import and variable; use `avg_score` directly in numeric GPA calculation.
C0121 / E711 / R1703 / R1705: comparisons and branching	Quality / style	32, 35-38	Equality comparison with `None` and unnecessary `if/else` obscure simple logic.	Use `is None`, guard missing/empty records, and return the comparison directly.
C0209 / E501 / C0304 / W292: formatting	Style	19, 34, 75	Old string formatting, two lines over 79 characters, and a missing final newline reduce consistency.	Use an f-string, split the long calculation using local variables, and end the file with a newline.

Additional behavior checks

Missing students and empty mark lists are handled deliberately. Scores and attendance updates have bounds. Invalid GPA scales raise clear errors. A main guard prevents output and grade-sheet creation during import. Equal weighting of marks is retained.

3. Before screenshots: Pylint and Flake8

Actual browser captures of the saved analyzer output. The surrounding report view labels the command and recorded exit status; the analyzer text is not rewritten.

PYLINT | BEFORE

Recorded exit code: 28

Complete saved analyzer output. Stdout followed by stderr.

```
python -m pylint --persistent=n student_grade_system.py
```

```
************* Module student_grade_system
student_grade_system.py:75:0: C0304: Final newline missing (missing-final-newline)
student_grade_system.py:15:0: C0116: Missing function or method docstring (missing-function-docstring)
student_grade_system.py:15:0: C0103: Function name "addGrade" doesn't conform to snake_case naming style (invalid-name)
student_grade_system.py:15:0: W0102: Dangerous default value [] as argument (dangerous-default-value)
student_grade_system.py:19:22: C0209: Formatting a regular string which could be an f-string (consider-using-f-string)
student_grade_system.py:23:0: C0116: Missing function or method docstring (missing-function-docstring)
student_grade_system.py:26:4: W0702: No exception type(s) specified (bare-except)
student_grade_system.py:30:0: C0116: Missing function or method docstring (missing-function-docstring)
student_grade_system.py:32:7: C0121: Comparison 'gradebook.get(student_id) == None' should be 'gradebook.get(student_id) is
None' (singleton-comparison)
student_grade_system.py:35:4: R1703: The if statement can be replaced with 'return bool(test)' (simplifiable-if-statement)
student_grade_system.py:35:4: R1705: Unnecessary "else" after "return", remove the "else" and de-indent the code inside it
(no-else-return)
student_grade_system.py:31:4: W0612: Unused variable 'grace_marks' (unused-variable)
student_grade_system.py:41:0: C0116: Missing function or method docstring (missing-function-docstring)
student_grade_system.py:44:10: W0123: Use of eval (eval-used)
student_grade_system.py:43:4: W0612: Unused variable 'avg_score' (unused-variable)
student_grade_system.py:48:0: C0116: Missing function or method docstring (missing-function-docstring)
student_grade_system.py:52:0: C0116: Missing function or method docstring (missing-function-docstring)
student_grade_system.py:56:0: C0116: Missing function or method docstring (missing-function-docstring)
student_grade_system.py:57:8: W1514: Using open without explicitly specifying an encoding (unspecified-encoding)
student_grade_system.py:57:8: R1732: Consider using 'with' for resource-allocating operations (consider-using-with)
student_grade_system.py:63:0: C0116: Missing function or method docstring (missing-function-docstring)
student_grade_system.py:6:0: W0611: Unused import json (unused-import)

-----------------------------------
Your code has been rated at 5.51/10
```

Lab 5 / Samarth Kotian / PES1UG24CS406 / 30 October 2026
Source: reports/before/pylint_report.txt

Figure 1. Pylint before: 5.51/10 and 22 messages.

FLAKE8 | BEFORE

Recorded exit code: 1

Complete saved analyzer output. Stdout followed by stderr.

```
python -m flake8 student_grade_system.py
```

```
student_grade_system.py:6:1: F401 'json' imported but unused
student_grade_system.py:19:80: E501 line too long (81 > 79 characters)
student_grade_system.py:26:5: E722 do not use bare 'except'
student_grade_system.py:31:5: F841 local variable 'grace_marks' is assigned to but never used
student_grade_system.py:32:34: E711 comparison to None should be 'if cond is None:'
student_grade_system.py:34:80: E501 line too long (83 > 79 characters)
student_grade_system.py:43:5: F841 local variable 'avg_score' is assigned to but never used
student_grade_system.py:75:7: W292 no newline at end of file
```

Lab 5 / Samarth Kotian / PES1UG24CS406 / 30 October 2026
Source: reports/before/flake8_report.txt

Figure 2. Flake8 before: all eight findings.

3. Before screenshot: Bandit

This screenshot shows the High and Medium findings. The complete Bandit output, including all three Low findings and metrics, appears in the report appendix.



BANDIT | BEFORE

Recorded exit code: 1

High and Medium finding excerpts. The full report is in the PDF appendix.

```
python -m bandit -r student_grade_system.py
```

```
>> Issue: [B307:blacklist] Use of possibly insecure function - consider using safer ast.literal_eval.
   Severity: Medium   Confidence: High
   CWE: CWE-78 (https://cwe.mitre.org/data/definitions/78.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b307-eval
   Location: .\student_grade_system.py:44:10
43          avg_score = sum(marks) / len(marks)
44          gpa = eval(gpa_expr)
45          return gpa

----------------------------------------

>> Issue: [B324:hashlib] Use of weak MD5 hash for security. Consider usedforsecurity=False
   Severity: High   Confidence: High
   CWE: CWE-327 (https://cwe.mitre.org/data/definitions/327.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b324_hashlib.html
   Location: .\student_grade_system.py:49:11
48      def generate_student_hash(student_id):
49          return hashlib.md5(student_id.encode()).hexdigest()
50

----------------------------------------

>> Issue: [B605:start_process_with_a_shell] Starting a process with a shell, possible injection detected, security issue.
   Severity: High   Confidence: High
   CWE: CWE-78 (https://cwe.mitre.org/data/definitions/78.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b605_start_process_with_a_shell.html
   Location: .\student_grade_system.py:60:4
59          f.close()
60          os.system("echo Grade sheet exported to: " + filename)
61
```

Lab 5 / Samarth Kotian / PES1UG24CS406 / 30 October 2026
Source: reports/before/bandit_report.txt

Figure 3. Unsafe eval, weak MD5 and shell execution.

Severity	High	Medium	Low	Total
Original findings	2	1	3	6

4. After screenshots: Pylint and Flake8

All checks were rerun on the final corrected file.

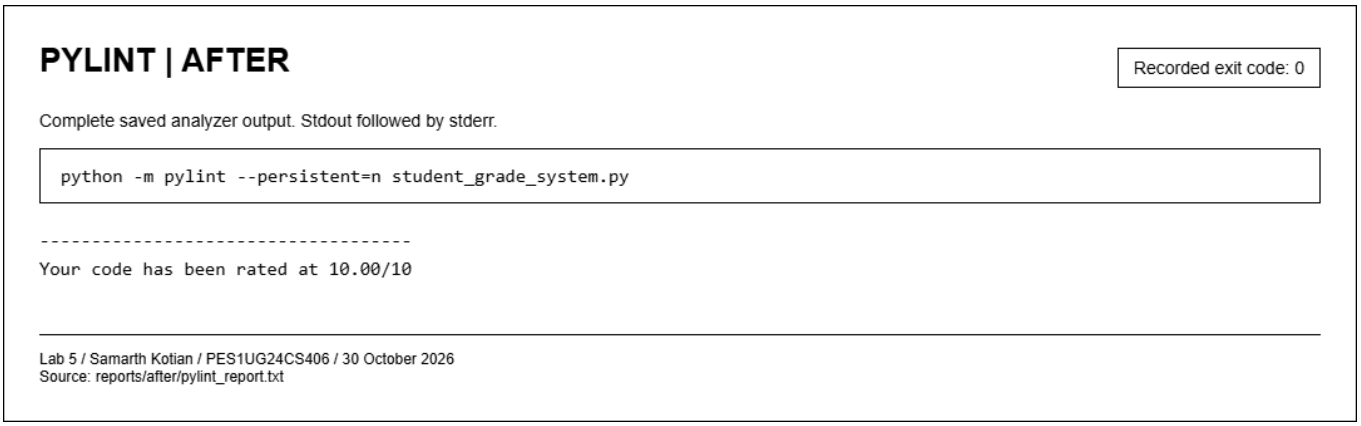


Figure 4. Pylint after: 10.00/10; exit code 0.

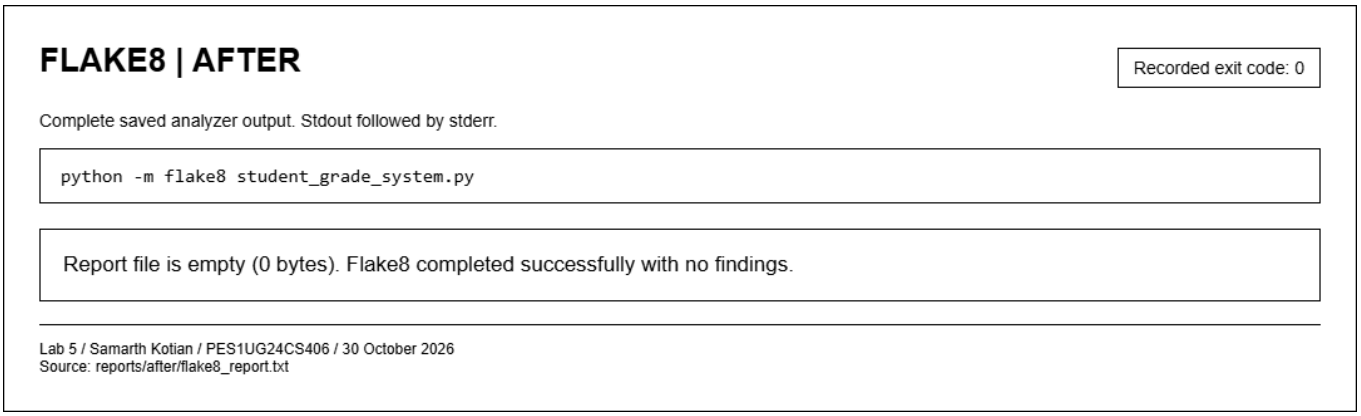


Figure 5. Flake8 after: no output; exit code 0. The status message belongs to the report view; the raw file is empty.

Flake8 success is silent. The PDF explicitly represents the zero-byte after report without inventing analyzer output.

4. After screenshot: Bandit and verification



BANDIT | AFTER

Recorded exit code: 0

Complete saved analyzer output. Stdout followed by stderr.

```
python -m bandit -r student_grade_system.py
```

```
Run started:2026-10-30 03:14:07.777922+00:00

Test results:
        No issues identified.

Code scanned:
        Total lines of code: 78
        Total lines skipped (#nosec): 0
        Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXX): 0

Run metrics:
        Total issues (by severity):
                Undefined: 0
                Low: 0
                Medium: 0
                High: 0
        Total issues (by confidence):
                Undefined: 0
                Low: 0
                Medium: 0
                High: 0
Files skipped (0):
[main]  INFO    profile include tests: None
[main]  INFO    profile exclude tests: None
[main]  INFO    cli include tests: None
[main]  INFO    cli exclude tests: None
[main]  INFO    running on Python 3.12.14
```

Lab 5 / Samarth Kotian / PES1UG24CS406 / 30 October 2026
Source: reports/after/bandit_report.txt

Figure 6. Bandit after: no issues at any severity; exit code 0.

Functional verification

Ten regression tests pass. They cover score validation and audit logs; attendance bounds; passing boundaries and missing marks; numeric GPA scaling; rejection of code strings and invalid scales; SHA-256; cryptographic PIN bounds; literal shell characters in export filenames; token redaction; and safe import.

Final sample output

```
Is S01 passing: True
Calculated GPA: 4.35
Student Hash: ac7438e86cb85ebd90f4d0abb235f9a28f112e1ec0b7995156f3d5e868d315f8
Registration PIN: 1634
Grade sheet exported to: grade_sheet.txt
Portal token active: False
```

The PIN varies per run. The token status is False when no environment token is configured. The digest is an identifier hash, not encryption or a password-storage scheme.

5. Reflection

The supplied handout omits the reflection question text. The following four standard questions address its stated learning outcomes, as requested.

1. How did Pylint, Bandit, and Flake8 help improve this program?

Pylint highlighted maintainability and reliability problems such as the shared mutable default list, missing docstrings, unused code, and unmanaged file handling. Flake8 identified concrete style and correctness issues, including a bare exception, comparison with `None`, unused names, long lines, and the missing final newline. Bandit focused on security: it identified unsafe `eval`, MD5, shell execution, predictable PIN generation, an embedded token, and silent exception handling. Their overlapping findings helped verify the same repairs from different perspectives. The final results were Pylint 10.00/10, zero Bandit findings, and zero Flake8 findings.

2. Which issues were most important, and how were they prioritized?

The two High findings were addressed first in the security review: MD5 was replaced by SHA-256 and the shell command was removed. The Medium `eval` finding was replaced by direct arithmetic with a validated numeric scale. The Low security findings were also fixed: cryptographic randomness now generates the PIN, the token comes from the environment and is never printed, and invalid attendance updates are handled explicitly. Quality and formatting repairs followed. A secure digest does not make low-entropy student identifiers private, and a four-digit PIN still requires rate limiting in a real authentication system.

3. What was challenging about fixing the issues while preserving behavior?

The main challenge was removing `eval` without changing the demonstrated GPA. The original string `avg_score / 20.0` is now a numeric scale with default 20.0. After recording S01's score of 95, the GPA remains 4.35. Arbitrary expression strings are intentionally rejected. Another important change was replacing the shared list default with `None` while retaining caller-supplied audit logs. Explicit tests checked attendance updates, passing boundaries, invalid inputs, safe export filenames, import behavior, and token redaction. All ten tests passed.

4. What are the limitations of static analysis, and how would it be used again?

A clean report cannot prove functional correctness or complete security. Static analysis does not establish that grading rules match institutional policy, that attendance is modeled correctly, or that authentication has suitable rate limits. Flake8 also marked `avg_score` as unused because its use was hidden inside an evaluated string, showing why findings need interpretation. I would combine all three tools with code review and behavior tests, and run them before commits or in continuous integration. Small commits for each tool make fixes easier to review. Reports should record tool versions, original line numbers, and before-and-after results so the improvements can be reproduced.

6. Commit record and reproducibility

Commit	Purpose
1f0e81b	lab5: preserve supplied program and baseline analysis reports
c0d9210	lab5: fix Pylint quality, mutable defaults, and error handling
175fee9	lab5: resolve Bandit security findings and verify grade behavior
03c8294	lab5: fix Flake8 line lengths and finalize PEP 8 formatting

The baseline commit preserves the original source and initial reports. The next three separate commits contain Pylint, Bandit, and Flake8 fixes. Supporting documentation and the PDF are packaged separately after these fixes.

Reproduce the analysis

```
python -m venv .venv
.venv\Scripts\python.exe -m pip install -r requirements.txt
.venv\Scripts\python.exe -m pylint --persistent=n student_grade_system.py
.venv\Scripts\python.exe -m bandit -r student_grade_system.py
.venv\Scripts\python.exe -m flake8 student_grade_system.py
.venv\Scripts\python.exe -m unittest -v
```

Original sample output

```
Grade sheet exported to: grade_sheet.txt
Is S01 passing: True
Calculated GPA: 4.35
Student Hash: 4cfe35d8825ba802868fabe687dc860d
Registration PIN: 7506
Portal token active: ADMIN_GRADE_PORTAL_TOKEN_2026
```

The original export message appeared first because the shell and Python output streams were buffered differently. The final program prints directly without creating a shell.

Capture method

Each analyzer was run as a subprocess against the same target filename. The raw reports contain stdout followed by stderr; neither stream was filtered. Recorded exit codes are included in the repository. Bandit timestamps are UTC. Screenshots are browser views of the saved reports, rather than terminal captures. The appendix reproduces all six report contents.

7. Complete report contents

All six requested .txt reports are reproduced below. Long lines are wrapped for page width; no finding or report text is omitted. Raw originals remain in the Git repository.

PYLINT - BEFORE

reports/before/pylint_report.txt

```
************* Module student_grade_system
student_grade_system.py:75:0: C0304: Final newline missing (missing-final-newline)
student_grade_system.py:15:0: C0116: Missing function or method docstring (missing-function-docstring)
student_grade_system.py:15:0: C0103: Function name "addGrade" doesn't conform to snake_case naming style
(invalid-name)
student_grade_system.py:15:0: W0102: Dangerous default value [] as argument (dangerous-default-value)
student_grade_system.py:19:22: C0209: Formatting a regular string which could be an f-string
(consider-using-f-string)
student_grade_system.py:23:0: C0116: Missing function or method docstring (missing-function-docstring)
student_grade_system.py:26:4: W0702: No exception type(s) specified (bare-except)
student_grade_system.py:30:0: C0116: Missing function or method docstring (missing-function-docstring)
student_grade_system.py:32:7: C0121: Comparison 'gradebook.get(student_id) == None' should be
'gradebook.get(student_id) is None' (singleton-comparison)
student_grade_system.py:35:4: R1703: The if statement can be replaced with 'return bool(test)'
(simplifiable-if-statement)
student_grade_system.py:35:4: R1705: Unnecessary "else" after "return", remove the "else" and de-indent the code
inside it (no-else-return)
student_grade_system.py:31:4: W0612: Unused variable 'grace_marks' (unused-variable)
student_grade_system.py:41:0: C0116: Missing function or method docstring (missing-function-docstring)
student_grade_system.py:44:10: W0123: Use of eval (eval-used)
student_grade_system.py:43:4: W0612: Unused variable 'avg_score' (unused-variable)
student_grade_system.py:48:0: C0116: Missing function or method docstring (missing-function-docstring)
student_grade_system.py:52:0: C0116: Missing function or method docstring (missing-function-docstring)
student_grade_system.py:56:0: C0116: Missing function or method docstring (missing-function-docstring)
student_grade_system.py:57:8: W1514: Using open without explicitly specifying an encoding (unspecified-encoding)
student_grade_system.py:57:8: R1732: Consider using 'with' for resource-allocating operations (consider-using-with)
student_grade_system.py:63:0: C0116: Missing function or method docstring (missing-function-docstring)
student_grade_system.py:6:0: W0611: Unused import json (unused-import)

-----------------------------------
Your code has been rated at 5.51/10
```

7. Complete report contents / continued

BANDIT - BEFORE

reports/before/bandit_report.txt

```
Run started:2026-10-30 03:09:23.873450+00:00

Test results:
>> Issue: [B110:try_except_pass] Try, Except, Pass detected.
   Severity: Low   Confidence: High
   CWE: CWE-703 (https://cwe.mitre.org/data/definitions/703.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b110_try_except_pass.html
   Location: .\student_grade_system.py:26:4
25          gradebook[student_id]["attendance"] += present_days
26      except:
27          pass
28

--------------------------------------------------
>> Issue: [B307:blacklist] Use of possibly insecure function - consider using safer ast.literal_eval.
   Severity: Medium   Confidence: High
   CWE: CWE-78 (https://cwe.mitre.org/data/definitions/78.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b307-eval
   Location: .\student_grade_system.py:44:10
43      avg_score = sum(marks) / len(marks)
44      gpa = eval(gpa_expr)
45      return gpa

--------------------------------------------------
>> Issue: [B324:hashlib] Use of weak MD5 hash for security. Consider usedforsecurity=False
   Severity: High   Confidence: High
   CWE: CWE-327 (https://cwe.mitre.org/data/definitions/327.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b324_hashlib.html
   Location: .\student_grade_system.py:49:11
48  def generate_student_hash(student_id):
49      return hashlib.md5(student_id.encode()).hexdigest()
50

--------------------------------------------------
>> Issue: [B311:blacklist] Standard pseudo-random generators are not suitable for security/cryptographic purposes.
   Severity: Low   Confidence: High
   CWE: CWE-330 (https://cwe.mitre.org/data/definitions/330.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b311-random
   Location: .\student_grade_system.py:53:11
52  def generate_registration_pin():
53      return random.randint(1000, 9999)
54

--------------------------------------------------
>> Issue: [B605:start_process_with_a_shell] Starting a process with a shell, possible injection detected, security
issue.
   Severity: High   Confidence: High
   CWE: CWE-78 (https://cwe.mitre.org/data/definitions/78.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b605_start_process_with_a_shell.html
   Location: .\student_grade_system.py:60:4
59      f.close()
60      os.system("echo Grade sheet exported to: " + filename)
61

--------------------------------------------------
>> Issue: [B105:hardcoded_password_string] Possible hardcoded password: 'ADMIN_GRADE_PORTAL_TOKEN_2026'
   Severity: Low   Confidence: Medium
   CWE: CWE-259 (https://cwe.mitre.org/data/definitions/259.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b105_hardcoded_password_string.html
   Location: .\student_grade_system.py:64:19
63  def main():
64      portal_token = "ADMIN_GRADE_PORTAL_TOKEN_2026"
65      addGrade("S01", 95)

--------------------------------------------------

Code scanned:
    Total lines of code: 55
    Total lines skipped (#nosec): 0
    Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXX): 0
```

```
Run metrics:
    Total issues (by severity):
        Undefined: 0
        Low: 3
        Medium: 1
        High: 2
    Total issues (by confidence):
        Undefined: 0
        Low: 0
        Medium: 1
        High: 5
Files skipped (0):
[main]  INFO    profile include tests: None
[main]  INFO    profile exclude tests: None
[main]  INFO    cli include tests: None
[main]  INFO    cli exclude tests: None
[main]  INFO    running on Python 3.12.14
```

7. Complete report contents / continued

FLAKE8 - BEFORE

reports/before/flake8_report.txt

```
student_grade_system.py:6:1: F401 'json' imported but unused
student_grade_system.py:19:80: E501 line too long (81 > 79 characters)
student_grade_system.py:26:5: E722 do not use bare 'except'
student_grade_system.py:31:5: F841 local variable 'grace_marks' is assigned to but never used
student_grade_system.py:32:34: E711 comparison to None should be 'if cond is None:'
student_grade_system.py:34:80: E501 line too long (83 > 79 characters)
student_grade_system.py:43:5: F841 local variable 'avg_score' is assigned to but never used
student_grade_system.py:75:7: W292 no newline at end of file
```

PYLINT - AFTER

reports/after/pylint_report.txt

```
-----------------------------------
Your code has been rated at 10.00/10
```

BANDIT - AFTER

reports/after/bandit_report.txt

```
Run started:2026-10-30 03:14:07.777922+00:00

Test results:
    No issues identified.

Code scanned:
    Total lines of code: 78
    Total lines skipped (#nosec): 0
    Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXX): 0

Run metrics:
    Total issues (by severity):
        Undefined: 0
        Low: 0
        Medium: 0
        High: 0
    Total issues (by confidence):
        Undefined: 0
        Low: 0
        Medium: 0
        High: 0
Files skipped (0):
[main]  INFO    profile include tests: None
[main]  INFO    profile exclude tests: None
[main]  INFO    cli include tests: None
[main]  INFO    cli exclude tests: None
[main]  INFO    running on Python 3.12.14
```

FLAKE8 - AFTER

reports/after/flake8_report.txt

This report is empty (0 bytes). Flake8 exited with code 0 and produced no findings. No report text has been added.